

CurveYield vISDT V18.9

Deep Assurance v16.2 Rehearsal Audit Report v1

Campaign	da6-vlsdt-v18-9-v162-rehearsal-7dee48511a
Skill release	ai-auditor-deep-assurance-v6@16.2.0
Controller pin	d09a925d4735da8acde24baf39a1de2fb90ddd2f
Exact source	CurveYield/Audits@1f63e0306ac35fdc4a8416064cc7aa606846e163
Source ZIP SHA-256	18ba0c39c30a741308b72102580d2e8a6e0832c8ef0ac04d027e4aea49e7f4ec
Completion	COMPLETE (rehearsal)
Security / release verdict	NO_GO

REHEARSAL BOUNDARY: One runtime executed all roles serially and the operator prohibited polls. No poll/task receipts were fabricated. No local Solidity compilation or dependency installation occurred; executable build/dependency/fork work ran on GitHub. This is not an independent multi-session certification.

1. Executive conclusion

The rehearsal completed all seven Deep Assurance role scopes and exercised the real GitHub source, execution, evidence, publication, and fetch-back surfaces. The exact active source compiles successfully, static and contract-size gates pass, and a pinned Ethereum fork simulation executed the new USDC -> wrapped WETH -> SDT route against live pool identities. Release is NO_GO because two unresolved Medium contract findings remain and the exact-source project test suite is red at 80 passing / 4 failing.

The two Medium findings are independent of the red test assertions: the revenue vault can cross totalSupply to zero while unharvested economic NAV remains, allowing a future depositor to inherit that value; and a protected cyGOV Yield Staking mint reservation can become safely unrecoverable after emergency minter revocation. A Low governance-operational issue remains for RevenueStaking admin-key recovery.

2. Execution model and limitations

- Roles executed serially: scope/specification, architecture/threat, manual implementation, economic/accounting, build/simulation evidence, adversarial/no-go, and final-report coordination.
- Durable GitHub campaign/lane mailboxes: CurveYield/audit-controller issues #53 through #60.
- No scheduled polls or ChatGPT tasks were used, by operator instruction.
- No local Solidity compilation and no local dependency downloads were performed.
- GitHub runners installed dependencies, compiled, ran Hardhat tests, ran static/size checks, and executed the pinned-fork simulation.
- Two targeted adversarial simulations were inconclusive because Ganache/ethers failed constructor gas estimation before the relevant assertions.
- Formal controller state-machine admission was represented by durable GitHub lane submissions/reconciliation rather than a separately running controller reducer service.

3. Exact source and scope

The user-supplied ZIP was independently hashed and matched to an immutable ZIP blob already staged in CurveYield/Audits at the exact source commit. The archive contains 223 files; 134 are active after excluding archive-do-not-run/; 42 active files are Solidity; and 15 top-level active CurveYield contracts are deployable contracts. Historical material under archive-do-not-run/ was excluded from active build/audit execution except as context.

4. Phase / gate matrix

Phase	Domain	Result	Disposition
1	Scope and provenance	PASS	Exact ZIP/Git source identity and archive boundary verified.
2	Risk specification	PASS	Privilege, asset-flow, accounting, external-integration, and release assumptions frozen.
3	Architecture / threat model	PASS	Cross-contract trust, migration, boost, converter, and governance boundaries reviewed.
4	Manual implementation review	PASS	15 top-level active contracts plus active interfaces/libraries manually reviewed.
5	Economic / mathematical review	PASS	Reward, fee, mint-reservation, decay, vault NAV, and rounding surfaces reviewed.
6	Exact build and tests	FAIL	Compile/static/size pass; full suite 80 pass / 4 fail. DA-VLSDT-RB01 unresolved.
7	Fork simulation / lifecycle	PASS	Pinned Ethereum route simulation passed all 19 structured steps.
8	Findings validation	PASS	Candidates challenged; 2 Medium + 1 Low accepted; route-timelock candidate rejected.
9	Remediation review	PASS*	No fixes applied; unresolved findings and release blocker are explicitly recorded. *Process concluded, not security cleared.
10	Release and report	EXTERNAL	Report/PDF/archive publication and fetch-back are recorded in the external publication manifest and GitHub receipt to avoid self-referential hashes.

5. Canonical findings

DA-VLSDT-001 - MEDIUM - Zero-supply vault can orphan unharvested economic NAV and allocate it to the next depositor

Status: UNREMIEDIATED

Description: The vault prices deposits and public economic PPFS against realized assets plus conservatively quoted unharvested rewards, but ordinary withdrawal burns shares against realized balance only. If the final shareholder exits while positive ordinary rewards remain unharvested, totalSupply can reach zero while economic reward NAV remains. The next deposit takes the supply==0 mint path and receives shares only for its contributed assets, thereby inheriting the orphaned prior reward NAV.

Impact: A permissionless timing-dependent value transfer can occur across the zero-supply boundary: the departing holder set can forfeit pending economic value and the next depositor can capture it.

Source anchors:

- contracts/CurveYieldRevenueVaultV7.sol:83-96 (economic NAV / PPFS)
- contracts/CurveYieldRevenueVaultV7.sol:143-159 (realized withdrawal)
- contracts/CurveYieldRevenueVaultV7.sol:203-219 (deposit mint path; supply==0)
- test/v18/RevenueVaultV18.test.js:90-113 (deposit pricing against unharvested rewards)

Recommended remediation: Before the final share burn, settle/harvest ordinary rewards or otherwise allocate the economic NAV. Alternatively, prevent supply from reaching zero while economic NAV remains or mint a defined orphan-NAV claim/sink. Add a regression for positive unharvested rewards -> final withdrawal -> next deposit.

DA-VLSDT-002 - MEDIUM - Protected Yield Staking mint reserve lacks safe emergency recovery after minter revocation

Status: UNREMIEDIATED

Description: Yield Staking creates protected quota-controlled mint reservations. Governance can immediately revoke the minter, but protected reservations cannot be owner-cancelled by a different address, and quota-controlled reservation consumption is blocked once the reservation minter is revoked. Yield Staking reserve rebalance/top-up paths also require its minter authority. There is no separate emergency cancellation path.

Impact: A material portion of global mint capacity can remain stranded after emergency revocation. Safe recovery may require re-authorizing the very contract that governance revoked because it was compromised or retired.

Source anchors:

- contracts/CurveYieldGovernanceToken.sol:238-275 (immediate revocation / delayed re-add)
- contracts/CurveYieldGovernanceToken.sol:474-535 (protected replacement / cancellation)
- contracts/CurveYieldGovernanceToken.sol:646-680 (revoked minter cannot consume quota-controlled reserve)
- contracts/CurveYieldCyGovYieldStaking.sol:358-371,526-552 (reservation rebalance/top-up)
- test/v18/CyGovYieldStakingV18.test.js:47-63 (protected reserve and normal release while authorized)

Recommended remediation: Add a tightly scoped, evented emergency recovery path for protected reservations whose minter is currently revoked, preferably delayed and incapable of increasing mint capacity. Add revoke -> release/cancel regression coverage without reauthorizing the revoked contract.

DA-VLSDT-003 - LOW - RevenueStaking admin role has no owner/DAO recovery path

Status: UNREMIEDIATED

Description: The current RevenueStaking admin alone can rotate the admin role. The owner cannot recover a lost or compromised admin. The role is the live destination for the 7% excess-yield admin share and is referenced by the Locker for the 5% admin boost allocation.

Impact: Loss of the admin key can permanently strand admin-role rotation; compromise lets the current admin transfer that role. This is primarily a governance/key-recovery availability risk, not direct user-principal theft.

Source anchors:

- contracts/CurveYieldVISDTRevenueStaking.sol:213-228 (onlyAdmin / setAdmin)
- contracts/CurveYieldVISDTRevenueStaking.sol:808-830 (33% Treasury + 7% admin split)
- contracts/CurveYieldVISDTLocker.sol:265-268,654-669 (admin authority / boost delegation)

Recommended remediation: If permanent separate-admin irrecoverability is not an explicit invariant, add a delayed DAO emergency recovery path. Otherwise document the immutable key-recovery assumption prominently.

6. Release blocker

DA-VLSDT-RB01 - Full exact-source project suite is red: 80 passing / 4 failing

Status: UNRESOLVED

- Function simulation callable inventory fixed-count assertion expects 743 but observes 744.
- Function simulation scenario-plan fixed-count assertion expects 743 but observes 744.
- Revenue benchmark test expects 635 tokens retained while also expecting 265 Treasury + 35 admin from a 1,000-token notification; those assertions sum to 935. Current V18.9 code/docs specify 33% Treasury + 7% admin on excess and the observed retained balance is 700.
- Vault cyGOV checkpoint assertion expects exactly 100e18 but observes 99.999999999999999999e18 (one wei difference).

Assessment: The failures appear to be stale regression expectations rather than compiler/runtime faults, but the package deployment runbook requires a fully passing suite. The build-and-test gate therefore fails until these assertions are corrected or justified and the exact-source suite reruns green.

7. Executable GitHub evidence

Evidence	Run	Result	Key result
Trusted active compile	31139592728	PASS	42 active source files; solc 0.8.28; zero diagnostics.
Pinned Ethereum route simulation	31137822104	PASS	19/19 steps; live pool identities; USDC -> WETH -> SDT route executed.
Exact full project suite	31140580753	FAIL	Compile PASS; static PASS; size PASS; tests 80 pass / 4 fail.
Root-project trusted compile	31139388475	SCOPE FAILURE	Only excluded archive-do-not-run historical imports failed; active contracts later compiled cleanly.

Evidence	Run	Result	Key result
Reservation adversarial fixture	31139955252	INCONCLUSIVE	Ganache/ethers constructor gas-estimation failure before first assertion.
Zero-supply adversarial fixture	31140136728	INCONCLUSIVE	Ganache/ethers string-constructor deployment failure before economic assertions.

Pinned-fork route result: at Ethereum block 25,500,000, a 100 USDC quote was approximately 1,089.0817 SDT and the route delivered approximately 1,105.1308 SDT to the buyer, while the route contract retained zero USDC and zero SDT.

8. Exact project test failure analysis

- Two function-simulation harness tests use a fixed expected count of 743; current source produces 744 callable/scenario entries. Inventory and scenario plan grew together, so the fixed count is stale.
- Benchmark-fee test expects 265 Treasury, 35 admin, and 635 retained from a 1,000-token notification; those values sum to 935. Current V18.9 code/docs specify 33% Treasury + 7% admin on excess and the observed retained balance is 700.
- Vault checkpoint test expects exactly 100e18 cyGOV but observes 100e18 - 1 wei, a rounding-expectation mismatch.
- Despite the likely test-assertion nature of these failures, a red exact-source suite violates the package release gate.

9. Rejected / downgraded candidates

- Immediate RevenueConverter.setUsdcRoute() replacement: rejected as unintended vulnerability because the exact package explicitly tests immediate configuration and states no route timelock was added. It remains a privileged trust surface.
- Governance proposal-sync replay: rejected after confirming chain, contract, caller, cursor, proposal-list hash, and deadline binding plus cursor advancement.
- Emergency strategy retirement: not promoted; seven-day candidate delay is preserved and old strategy is permanently retired/paused.
- Root-project trusted compile failure: not promoted; only excluded archive-do-not-run historical imports failed, while active source compiled cleanly.

10. Remediation and residual risk

No contract modifications were requested or applied. DA-VLSDT-001, DA-VLSDT-002, and DA-VLSDT-003 remain unrepaired. DA-VLSDT-RB01 remains unresolved.

- Fix the zero-supply orphan-NAV path and add targeted regression coverage.
- Add safe emergency release/cancellation for protected reservations after minter revocation and add revoke/recovery regression coverage.
- Decide whether RevenueStaking admin irrecoverability is intentional; document it or add delayed DAO recovery.
- Correct/justify all four failing exact-source tests and rerun the full suite to green.
- Re-run Deep Assurance build/test, adversarial validation, and finalization on the remediated exact commit.

11. Final verdict

completionStatus: COMPLETE (rehearsal)

securityVerdict: NO_GO

Unresolved launch blockers: DA-VLSDT-001, DA-VLSDT-002, DA-VLSDT-RB01. DA-VLSDT-003 is Low and non-blocking by itself but remains unresolved.

Exact final artifact hashes and GitHub fetch-back identities are recorded after rendering in the external publication manifest, rather than embedded here, to avoid self-referential digest cycles.

12. Durable GitHub record

- Campaign index: CurveYield/audit-controller#53.
- Lane mailboxes: CurveYield/audit-controller#54 through #60.
- Contract-automation evidence PR: CurveYield/contract-automation#166 (evidence-only; close without merge).
- Exact-source project-test evidence PR: CurveYield/Audits#4 (evidence-only; close without merge).
- Final publication branch: CurveYield/audit-controller@rehearsal/vlsdt-v18-9-v162-7dee48511a.